元代謝　上線前總檢查報告

2026-10-18　｜　從每個角色的角度，重點看「後台整合」

結論：前後台的功能與權限是接得起來的，沒有發現會讓畫面壞掉的問題。我找到 4 個後端風險並已修好（都不用改前端）。**你只要重新部署一次後端，再做完「上線檢查清單」的 6 件必做，就可以開放。**

一、我怎麼檢查的（以及沒檢查到的）

已檢查	還沒辦法檢查（需要你或你的電腦）
① 後端約 350 個功能逐一核對：哪些要登入、哪些公開、哪些限定角色 ② 前端三個網頁呼叫的功能，後端都存在（無缺漏） ③ 8 種後台角色用模擬登入，把每個頁面都打開一次：沒有 JS 錯誤、選單與權限表完全一致 ④ 客人 App 7 個主頁面打開：沒有錯誤 ⑤ 新修的登入鎖定、付款防重複、新增客人，都用模擬資料跑過 ⑥ 動到錢的功能有沒有鎖、有沒有防連按	• **線上目前的版本**：我的 Chrome 連線一直連不上，沒辦法驗證你 GitHub 上現在是哪一版 • **觸發器有沒有建**（只能在 Apps Script 畫面看） • **試算表裡的真實資料**（我不碰真實客人資料，也看不到密碼） • **LINE 真機**：登入、推播、LIFF 實際行為 • 廠商頁只做程式碼核對，沒有模擬登入

二、各角色走查結果

角色	可見頁面	後端把關	結果
創始人／管理人	32	全部。帳號管理、IRCT 定價、刪客人、經營指標限創始人	通過
秘書	22	可編輯客人；看不到財務規則、帳號、薪資總表	通過
行政	10	客人資料唯讀（除非創始人開放）；可改商品定價	通過
會計	7	客人唯讀；不能改分帳規則／分帳角色	通過
財務主管	7	可改分帳規則、分帳角色、儲值優惠、商品定價	通過
醫師	8	客人預設唯讀；診斷、加測建議、運動甜蜜點可寫	通過
教練	1	後端只放行 15 個動作，且只能看「指派給自己」的學員	通過
廠商	—	每個動作都要代碼＋查詢密碼；現在加了連錯鎖定	通過
客人	7 個主頁	每個個人資料動作都要簽章 token，無法偷看別人	通過

三、發現並已修好的 4 件事（需重新部署後端）

級別	問題	原本會發生什麼	現在

高	登入沒有次數限制（後台、客人、廠商）	有人可以用程式一直猜密碼。後台帳號密碼還不分大小寫，更好猜。	同一對象連錯 8 次鎖 15 分鐘，時間到自動解開，輸對歸零。已用模擬測過。
中	記付款可以連按	秘書手滑按兩次，付款記錄就多一筆，對帳對不起來。	8 秒內同客人、同項目、同金額、同方式視為同一筆，不重複記。
中	新增客人「檢查編號」與「寫入」之間沒鎖；編號大小寫沒統一	兩人同時建同一編號，可能都成功，之後兩位客人的記錄會混在一起（之前簡博士重複就是這類）。輸入小寫或前後有空格的編號，後面有些查詢會找不到。	檢查與寫入同一把鎖；編號一律存大寫、去空白。
低	自動提醒的「現在幾點」依 Apps Script 專案時區	如果專案時區沒設台北，早上提醒、午飯後提醒、下班前留言會差幾小時發出。	一律用台北時間算。

四、建議但這次沒改（需要你決定，或需要實測才安全）

級別	項目	說明	建議
高	預設帳號 admin／admin1234	程式裡寫著：帳號表不存在時會自動建這組帳號。我看不到你的試算表，不知道它還在不在。	上線前自己打開「🔐 後台帳號」確認沒有（清單第 3 項）
中	密碼以明文存在試算表	能打開試算表的人，就看得到所有員工密碼。	先把試算表共用名單縮到最小；之後可改成加密存放（要改登入與改密碼流程，建議上線穩定後做）
中	財務類「查詢」只靠前端藏頁面	結算、儲值總覽、獎勵與介紹費等，後端只確認「有登入」，不分角色。行政或醫師正常使用看不到入口，但如果有人懂技術、直接送請求，是拿得到的。同事都是自己人，所以風險低。	上線後一週，我把這幾個查詢加上角色限制；現在加怕誤擋到秘書日常用的畫面，需要實測
低	getPermission 公開	知道某個 LINE 使用者 ID 就能查到名字與角色；LINE ID 是長亂碼，猜不到。	先不動
低	午飯後 3.5 小時不是精算	系統用「記錄時間落在 11～17 點」判斷。	要精算需客人填午餐時間，等你決定
低	幾個「小」動作沒防連按	如新增獎勵、新增介紹、預約、購買。連按會多一筆，但不涉及金額。	上線後看實際情況再補

五、後端整合現況

- **自動化只有兩條觸發器**：每天 autoCareDaily、每小時 autoCareHourly。其他所有自動規則（連續沒記錄、壓力、生日、甜蜜點、打卡提醒）都掛在這兩條下面，所以只要確認這兩條存在就好。

- **鎖與重複送出保護**：儲值、消費、結算、庫存、廠商收款、排班、每日記錄、壓力標記等 28 個會動資料的功能都有寫入鎖；這次再補上付款與新增客人。
- **自動留言不會重複**：自動關懷都有「已發過」記錄，每小時跑也不會重複發（已實測）。
- **任一自動規則出錯不會拖垮其他規則**：每段各自包 try/catch，出錯只記 Log。